Medical practice cybersecurity proposal comparison worksheet

HELM

- Complete the common brief with the people responsible for IT and clinical operations, then give each bidder the same approved scope.
- Use one commitment record per proposal. Copy the status and document reference into the comparison. Attach extra records if you are comparing more than three proposals.
- Use Included, Separate, Excluded or Unanswered. For Separate, obtain a price and written scope. For Excluded, record who has agreed to cover the work. Keep assumptions Unanswered.
- Reference controlled documents in their approved location. Keep patient details, passwords, security findings and sensitive configurations out of this worksheet and initial vendor inquiries.

Common brief for all bidders

Practice identifier and review date

Approved scope document and version

Locations, operating hours and remote work

Staff groups, contractors and covered population

IT owner and support hours

Clinical decision-maker and alternate contact route

Privacy/security reviewer and professional-advice route

Requested start date and common comparison period

Workflow or workload	Systems and access involved	Current operator or vendor	Outage needs to discuss
Front desk and scheduling			
EHR and clinical-record access			
Referrals, billing and outgoing messages			
Email, identity and shared workstations			
Phones, tablets, imaging and clinical equipment			
Recovery of mail, files, EHR data and other records			

Commitments in one proposal

Use one copy of this section for each bidder.

Proposal A, B or C; supplier legal entity

Proposal date, version and validity

Service order and agreement references

Supported accounts and workstations

Match eligibility and exclusions to the common brief.

Status

Written reference

Provider action and hours

Practice or retained-provider work

Additional cost or unquoted work

EHR service and access boundary

Identify who operates the EHR and who protects access devices.

Status

Written reference

Provider action and hours

Practice or retained-provider work

Additional cost or unquoted work

Clinical equipment and other excluded systems

Record qualified support, change authority and accepted exclusions.

Status

Written reference

Provider action and hours

Practice or retained-provider work

Additional cost or unquoted work

Incoming email threats

Check reporting, investigation and escalation duties.

Status

Written reference

Provider action and hours

Practice or retained-provider work

Additional cost or unquoted work

Commitments in one proposal

Use one copy of this section for each bidder.

Proposal A, B or C; supplier legal entity

Proposal date, version and validity

Service order and agreement references

Outgoing patient-information delivery

Identify the approved service, setup, staff procedure and support.

Status

Written reference

Provider action and hours

Practice or retained-provider work

Additional cost or unquoted work

BAA and covered services

Record the applicable entity, agreement and service boundaries for adviser review.

Status

Written reference

Provider action and hours

Practice or retained-provider work

Additional cost or unquoted work

Downstream providers

Record ePHI handling and which party contracts with each provider.

Status

Written reference

Provider action and hours

Practice or retained-provider work

Additional cost or unquoted work

After-hours investigation and containment

Confirm operator, authority, hours and fallback contact.

Status

Written reference

Provider action and hours

Practice or retained-provider work

Additional cost or unquoted work

Commitments in one proposal

Use one copy of this section for each bidder.

Proposal A, B or C; supplier legal entity

Proposal date, version and validity

Service order and agreement references

Repair, restore and clinical continuity

Record who restores each workload, the authorized clinical lead and the check for a usable restore.

Status

Written reference

Provider action and hours

Practice or retained-provider work

Additional cost or unquoted work

Incident reporting and notification decisions

Separate provider reporting from the practice's adviser-reviewed notices.

Status

Written reference

Provider action and hours

Practice or retained-provider work

Additional cost or unquoted work

Assessment and ongoing evidence work

Check deliverables, reviewer, update cadence and questionnaire limits.

Status

Written reference

Provider action and hours

Practice or retained-provider work

Additional cost or unquoted work

Onboarding acceptance

Agree coverage checks, outstanding work and first review.

Status

Written reference

Provider action and hours

Practice or retained-provider work

Additional cost or unquoted work

Commitments in one proposal

Use one copy of this section for each bidder.

Proposal A, B or C; supplier legal entity

Proposal date, version and validity

Service order and agreement references

Renewal and exit

Check notices, charges, exports, access removal and transition support.

Status

Written reference

Provider action and hours

Practice or retained-provider work

Additional cost or unquoted work

Complete the response handoff for this proposal

Action	Responsible operator	Authority or approval	Hours and fallback contact	Written reference
Receive and investigate the alert				
Contain the supported device or account				
Repair the device and restore each affected workload				
Invoke the approved clinical downtime procedure				
Report the incident to the practice				
Assess and authorize external notices with advisers				

Compare the written answers

For each requirement, enter status plus the proposal or commitment-record reference. A missing answer remains Unanswered. Carry unresolved work into the decision record.

Requirement	Proposal A: status and reference	Proposal B: status and reference	Proposal C: status and reference
Supported accounts and workstations			
EHR service and access boundary			
Clinical equipment and other excluded systems			
Incoming email threats			
Outgoing patient-information delivery			
BAA and covered services			
Downstream providers			
After-hours investigation and containment			
Repair, restore and clinical continuity			
Incident reporting and notification decisions			
Assessment and ongoing evidence work			
Onboarding acceptance			
Renewal and exit			

Compare cost on the same scope and period

Cost or term	Proposal A	Proposal B	Proposal C
User/device basis, eligible population and minimum			
Onboarding, transition and additional licenses			
Recurring security service			
Secure delivery, EHR/device support and extra recovery			
Retained IT and separately authorized projects			
Annual adjustments and other quoted charges			
First-year total; unresolved amounts marked Unquoted			
Full initial term and committed cost			
Renewal notice, termination and exit charges			

Resolve gaps and record the decision

Decide which items must be resolved before signature. Obtain written acceptance from any other provider assigned excluded work, then request revised proposal language where needed.

Unresolved item	Required answer or action	Responsible person/provider	Due date	Written resolution

Preferred proposal and reason

Accepted exclusions and responsible providers

Contract revisions required before signature

Practice decision-maker and review date

IT, clinical and adviser reviews completed or pending

Onboarding acceptance check and first review date

Hypothetical entry

Illustration only. This does not describe a customer, an actual proposal or a Helm commitment.

Field	Example
Requirement	Recovery of a front-desk workstation
Status	Unanswered
Written reference	Illustrative proposal A describes investigation and isolation only.
Provider action and hours	Bidder must confirm its investigation hours and containment authority.
Practice or retained-provider work	IT has not yet accepted repair and restore work. The practice must confirm the clinical downtime contact.
Additional cost or unquoted work	Unquoted
Next step	Obtain IT's written recovery scope and price, then reconcile the handoff with the bidder before deciding.

References

- Companion guide
- HHS risk analysis
- HHS cloud guidance